Report Exploit DVWA - XSS e SQL injection

Configurazione dell'ambiente

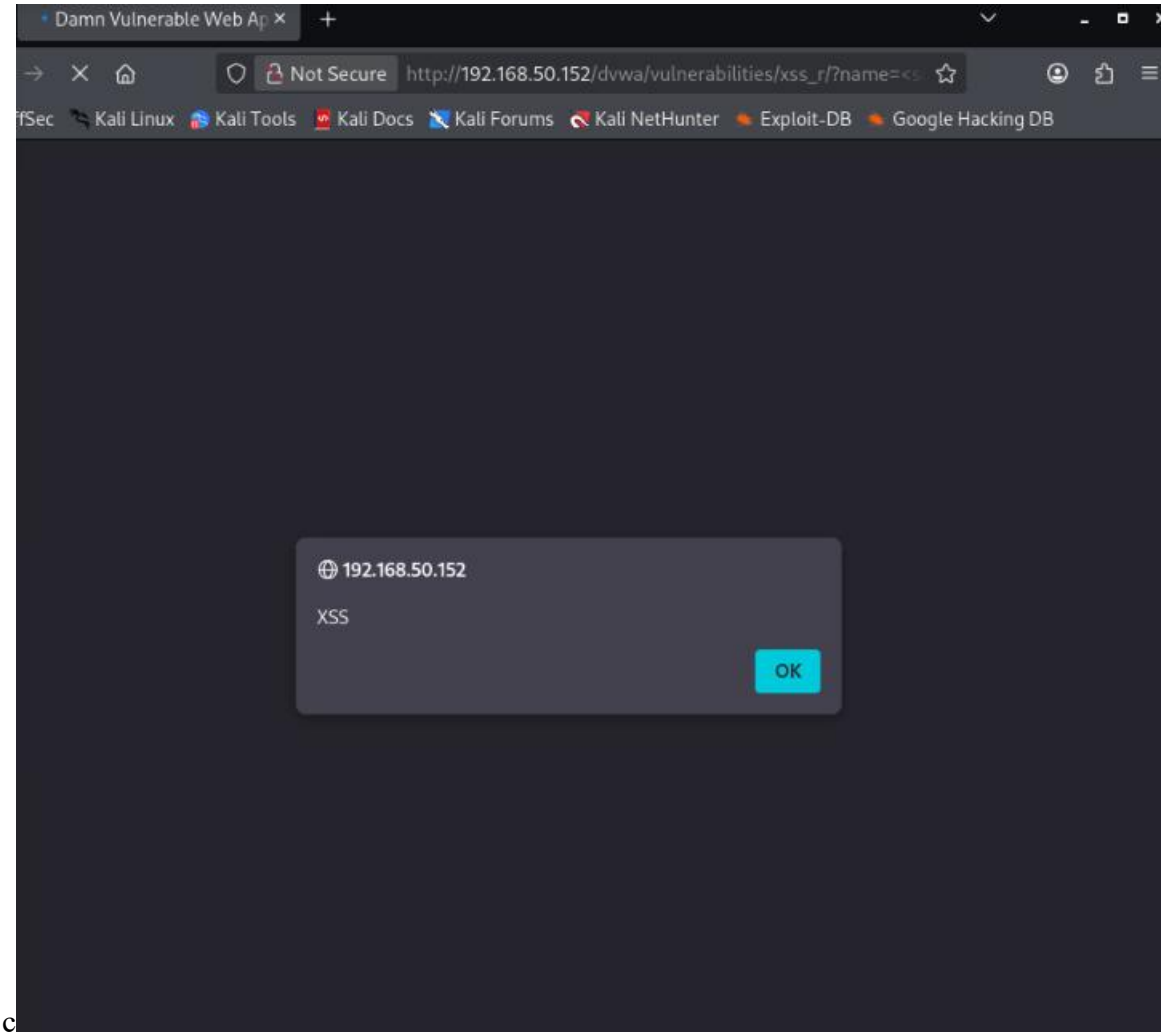
Macchine utilizzate:

- Kali Linux: attaccante
- Metasploitable: Bersaglio
- Applicazione vulnerabile: DWA
- Security level: low
- Ping funzionante

XXS Reflected

Vulnerabilità che permette ad un attaccante di iniettare il codice JavaScript malevolo in una pagina web. Il codice viene riflesso dal server al browser della vittima.

1. Accesso alla sezione XSS di DWA
2. È stato inserito: <script>alert('XSS')</script>
3. Inviata la richiesta



c

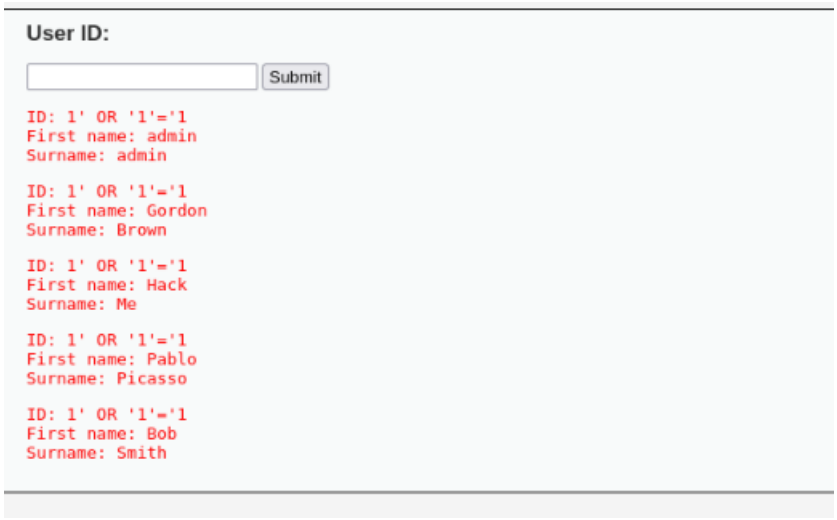
Il server ha elaborato l'input e lo ha restituito nella pagina HTML senza sanitizzarlo. Il browser ha interpretato il tag script eseguendo il codice JavaScript e generando un popup di avviso.

SQL Injection

Permette di manipolare la query al database backend inserendo comandi SQL nei campi di input

- Nel campo User ID è stato inserito: 1' OR '1'='1

Questo payload forza la condizione query ad essere sempre vera, restituendo l'intera tabella degli utenti.

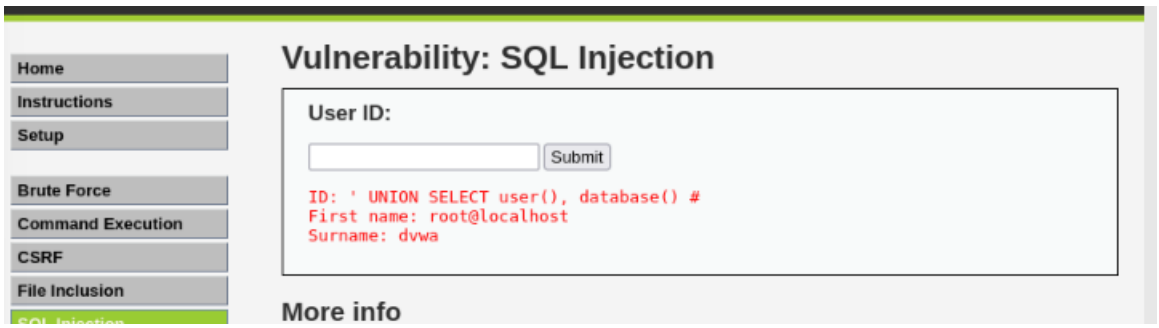


UNION SELECT

Per ottenere informazioni più specifiche è stata utilizzata la clausola UNION per unire i risultati della query originale con una query personalizzata.

È stato inserito: ' UNION SELECT user(), database() #

Il sistema ha restituito l'utente del database root@localhost e il nome del database corrente dvwa

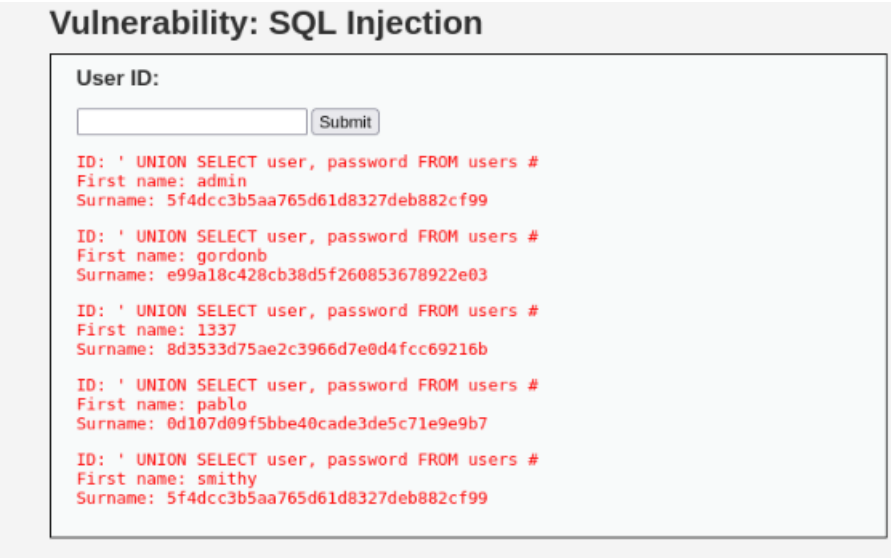


Estrazione delle credenziali

È stata eseguita una query per estrarre i nomi utente e le relative password

È stato inserito: ' UNION SELECT user, password FROM users #

E sono stati estratti con successo gli hash delle password degli utenti.



Password cracking

Una volta ottenuti gli hash, l'obiettivo è stato recuperarne il testo in chiaro (password originali), utilizzando un attacco a dizionario

Strumenti utilizzati:

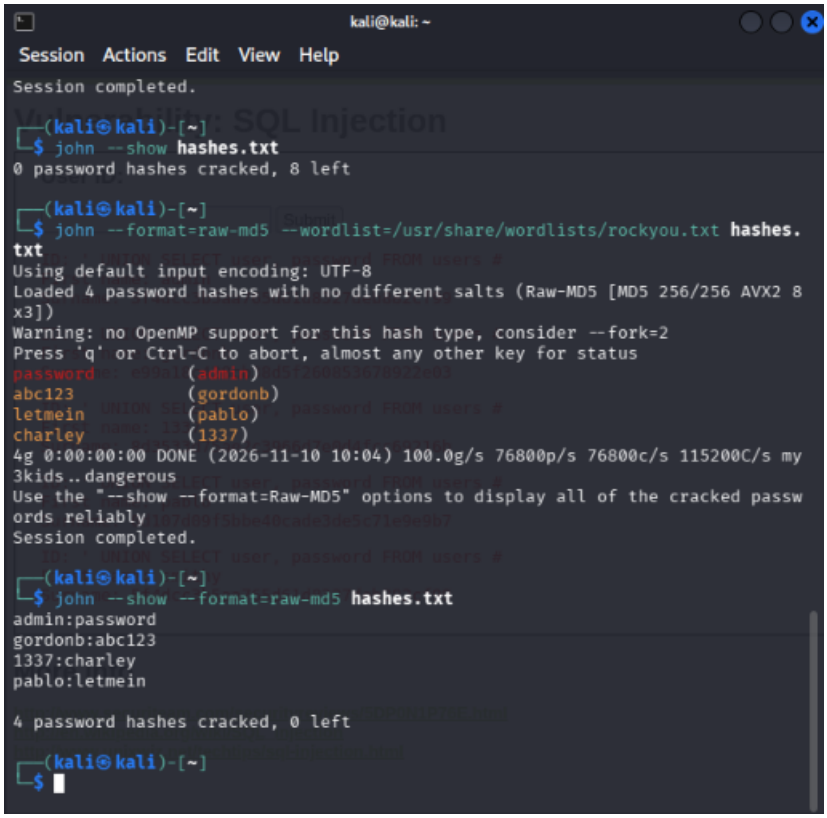
- John the Ripper: software per cracking password
- Rockyou.txt: wordlist con milioni di password comuni

Procedura:

1. Gli hash estrarri sono stati salvati in un file di testo (hashes.txt) nel formato utente:hash
2. È stata decompressa la wordlist di sistema: sudo gzip -d /usr/share/wordlists/rockyou.txt.gz
3. È stato lanciato l'attacco forzando il formato MD5: john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt hashes.txt

Risultati

Tutte le password sono state craccate in pochi secondi a causa della debolezza dell'algoritmo MD5 e della semplicità delle password scelte



Conclusioni

Il laboratorio ha dimostrato come una catena di vulnerabilità (XSS e SQi) possa portare alla compromissione totale dei dati sensibili, incluse le credenziali di accesso.